

基于 LLM 的重入漏洞分析实验

一、实验内容

本实验旨在设计一个基础的智能合约 安全分析流程, 用于辅助发现智能合约中的重入漏洞。

尝试利用大语言模型(LLM)对智能合约代码进行分析, 并探索如何结合其他分析工具或方法, 为模型提供更有针对性的上下文信息, 从而辅助漏洞判断。

二、实验背景

重入漏洞(Reentrancy)是智能合约中的一种经典安全问题。攻击者可以通过回调函数重新进入相关逻辑, 导致状态不一致或资产损失。

Pre-requisites

- 理解 Solidity 智能合约的基本结构与常见语法
- 初步了解智能合约中重入漏洞的基本原理;

三. 实验任务

1. 尝试使用 LLM 对智能合约进行漏洞分析;
2. 思考如何输入给 LLM 更有针对性的上下文, 并设计合适的 Prompt, 使模型更能 focus 合约中的关键逻辑;

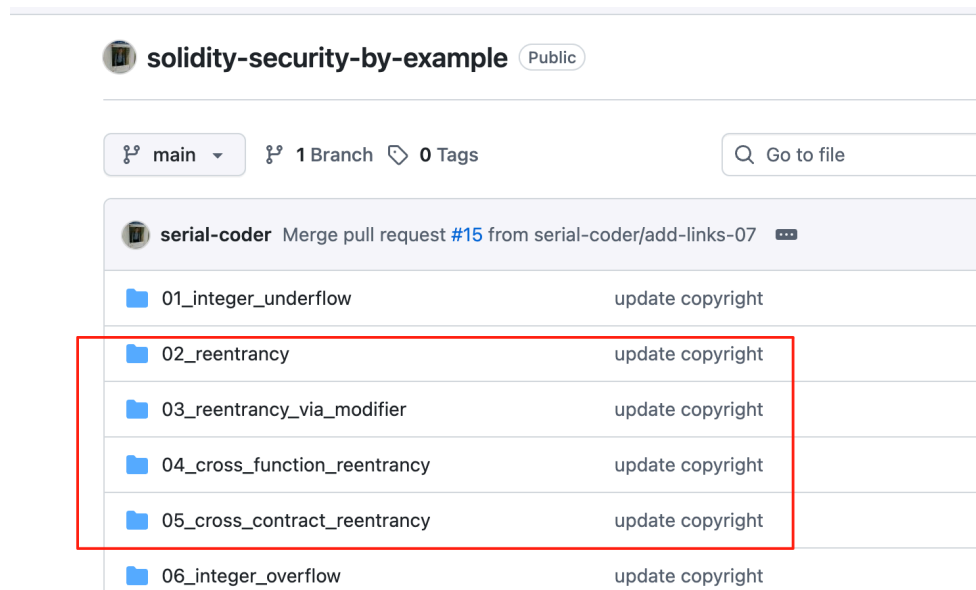
可以尝试不同方案改进 LLM 的分析效果, 例如

1. 可以考虑对代码进行适当裁剪, 只保留与漏洞相关的代码片段;
2. 可以考虑尝试使用静态分析工具(例如 Slither, 其提供 Python API)提取部分静态分析信息;
3. 可以考虑使用 Prompt Engineering、RAG 或其他方式提高 LLM 分析结果的质量;
4. 可以尝试设计多合约系统中的重入漏洞检测方案。

测试集(可以自己找一些现有合约)

例如:

<https://github.com/serial-coder/solidity-security-by-example/>



或者找一些真实的链上合约(不一定需要有重入漏洞), 例如下面的三个以太坊主网上的合约(可以用etherscan查看其代码):

0xf91546835f756DA0c10cFa0CDA95b15577b84aA7

0xbb9bc244d798123fde783fcc1c72d3bb8c189413

0x0eee3e3828a45f7601d5f54bf49bb01d1a9df5ea

三. 提交要求 (GitHub 仓库)

1. 创建一个github仓库
2. 上传分析脚本代码 和 给LLM的prompt